Legacy Portal Frontend

Final Technical Documentation

Version	1.0
Prepared for	IG-Techonology
Prepared by	saad farooq
System	Legacy Portal Frontend (Next.js)

> *Single-source handover document for architecture, API integration, access control, subscription gating, and QA/UAT checklist.*

1. Architecture Overview

Stack

Concern	Choice
Framework	Next.js `16.0.10` (App Router, `app/` directory)
UI runtime	React `19.2`
Language	TypeScript `5`
Styling	Tailwind CSS `4` + `tailwindcss-animate` / `tw-animate-css`
Components	Radix UI primitives wrapped in `components/ui/*` (shadcn-style)
Data fetching	SWR `2.3.8`
Charts	Recharts `2.15.4`
Toasts	Sonner
Icons	lucide-react / @tabler/icons-react
Theming	next-themes (`light` , `dark` , `client`)
PDF export	jsPDF + jspdf-autotable + svg2pdf / html2canvas
Auth tokens	Custom REST wrapper over Google Identity Toolkit (no client Firebase Auth SDK session)

Two backends (important)

The frontend talks to **two** different origins:

1. **Same-origin Next.js route handlers** (`app/api/auth/*`) — a thin proxy for authentication so the Firebase/Identity Toolkit API key stays server-side. Routes:
   - `POST /api/auth/sign-in`

- `POST /api/auth/sign-up`
- `POST /api/auth/refresh`
- `POST /api/auth/update-password`
- `GET /api/dev/firebase-env` (development diagnostics only)

2. **Cloud Run business API** — all data/business endpoints (gateways, devices, telemetry, users, clinic users, analytics, subscription, reports). Base URL is hardcoded in `lib/portal-config.ts`: `https://legacy-portal-api-test-601431816450.europe-west2.run.app`

Request/auth flow

```
Browser
  |  email/password
  ▼
/api/auth/sign-in (Next route)  ──►  Google Identity Toolkit (server-side, key
hidden)
  |  { idToken, refreshToken }
  ▼
AuthProvider (contexts/auth-context.tsx)
  - persists refreshToken in sessionStorage
  - decodes JWT claims (clinicId, role)
  - exposes getToken() to the API client
  ▼
lib/api/client.ts  ──►  Cloud Run API   (Authorization: Bearer <idToken>)
  - on 401: refresh token once, retry, else redirect /login
  - on 402 / payment_required: dispatch paywall event
  - on 403 provisioning codes: redirect to /account/*
  - reads X-Subscription-Warning: past_due header → past-due banner event
```

- ID tokens auto-refresh ~2 minutes before expiry (`RestAuthUser.getIdToken`).
- Parallel refreshes are coalesced (`refreshInFlight` map) to avoid token stampede on first paint.

Trial mode

`TrialProvider` (`contexts/trial-context.tsx`) calls `GET <api>/health` on boot. If the backend reports `trialMode: true`, the app runs without Bearer auth against a fixed trial clinic, and subscription/clinic gating is relaxed. Controlled at build time by `NEXT_PUBLIC_TRIAL_MODE` as a fallback when `/health` is unreachable.

Provider tree (`app/layout.tsx` → `components/providers.tsx`)

```
ThemeProvider
 └─ TrialProvider
     └─ AuthProvider
         └─ AutoRefreshSWRConfig        (global SWR refresh interval from settings)
             └─ LatestReadingProvider
                 └─ AppLayout            (shell, route guards, paywall)
```

2. Module Map

Routes (`app/`)

Route	Purpose	Notes / access
`/`	Dashboard overview	authenticated
`/analytics`	Analytics dashboard	authenticated
`/gateways` , `/gateways/[id]`	Gateway list + detail	authenticated
`/devices` , `/devices/[id]`	Device list + detail	authenticated
`/devices/compare`	Side-by-side device comparison	authenticated
`/compliance`	Compliance view	authenticated
`/latest-reading`	Latest readings view	authenticated
`/users` , `/users/[id]`	Clinic users directory (read)	hidden for doctor/nurse/readonly
`/people`	Staff management	admin/super_admin (non-personal)
`/email-automation`	Manual report send + schedules	admin/super_admin (+ doctor for schedules)
`/payment`	Billing & subscription	admin/super_admin only
`/payment/success` , `/payment/cancelled`	Stripe redirect landing pages	shell-less
`/settings`	Auto-refresh + preferences	authenticated
`/login` , `/signup` , `/forgot-password`	Auth screens	public
`/account/pending-clinic`	Provisioning waiting state	redirected by API 403 codes
`/alerts` , `/payments`	Secondary views	authenticated

Key libraries (`lib/`)

File	Responsibility
`lib/api/client.ts`	Single API client: all Cloud Run calls, auth header injection, 401 retry, error interceptors, SWR fetchers.
`lib/api/types.ts`	All request/response TypeScript types.
`lib/api/api-error.ts`	`ApiError`, `API_ERROR_CODES`, `isApiError`.
`lib/portal-config.ts`	Hardcoded Cloud Run base URL + Firebase web config.
`lib/identity-toolkit-rest.ts`	Client-side auth REST wrapper, token persistence.
`lib/identity-toolkit-core.ts`	Server-side Identity Toolkit calls.
`lib/auto-refresh-settings.ts`	Reads/writes SWR auto-refresh prefs.
`lib/serial-number.ts`	Serial number formatting helpers.
`lib/device-status.ts` ...	Domain formatting/derivation.
`lib/pdf/*`	PDF report generation.

Contexts & Components

- **`contexts/auth-context.tsx`**: `user`, `userInfo`, `signIn/signUp/signOut`, `getToken`, `subscriptionStatus`, `isSuperAdmin`.
- **`contexts/trial-context.tsx`**: `trialMode`, `loading`.
- **`contexts/latest-reading-context.tsx`**: Shared latest-reading state.
- **`components/layout/`**: `app-layout` (shell + guards + paywall), `sidebar`, `header`, `footer`.
- **`components/ui/`**: Shared design-system primitives (~90 components).

3. API Integration Guide

All business calls are centralized in `lib/api/client.ts`.

Standard envelope:

```
// success
{ "success": true, "data": <T>, "cursor": { "next": "<token>" } }

// error
{ "success": false, "error": { "code": "<code>", "message": "<text>" } }
```

Client primitives

Export	Use
`fetchApi<T>(path, options?)`	Authenticated JSON request; throws `ApiError` on non-2xx
`fetcher(url)`	SWR fetcher (unwraps `data`)
`packetFetcher`, `cursorFetcher`	SWR fetchers for paginated responses
`setAuthTokenGetter`, `setFallbackIdToken`	Wired by `AuthProvider` to attach `Authorization`
`isApiError`, `API_ERROR_CODES`	Error narrowing + known backend codes

Endpoint usage by module

Authentication proxy (`app/api/auth/*`)		
`signInWithPassword`	POST	`/api/auth/sign-in`
`signUp`	POST	`/api/auth/sign-up`
`refreshIdToken`	POST	`/api/auth/refresh`
Session/profile		
`getAuthMe`	GET	`/api/auth/me`
`claimClinic(code)`	POST	`/api/auth/claim-clinic`
Gateways & Devices		
`getGateways`	GET	`/api/gateways`
`getDevices`	GET	`/api/devices`
`getDeviceCompare(...)`	GET	`/api/devices/compare?left&right&days`
Users / clinic staff		
`getUsers`	GET	`/api/users*`
`createClinicUser`	POST	`/api/clinic/users`
Reports / scheduler		
`sendReportEmail`	POST	`/api/reports/email/send`
`listReportSchedules`	GET	`/api/reports/email-automation/schedules`
Billing / subscription		
`getSubscriptionStatus`	GET	`/api/subscription/status`
`createSubscriptionCheckout`	POST	`/api/subscription/create-checkout`

4. Access Control & Subscription

UI visibility matrix

Module / action	super_admin	admin	doctor	nurse	readonly
Dashboard / devices / gateways	✅	✅	✅	✅	✅
Users directory (`/users`)	✅	✅	❌	❌	❌
Staff management (`/people`)	✅	✅*	❌	❌	❌
Email automation manual send	✅	✅	❌	❌	❌
Email automation schedules	✅	✅	✅	❌	❌
Billing (`/payment`)	✅	✅	❌	❌	❌

* admin requires non-personal clinic account.

Subscription gating flow

Backend contract for protected routes:

- `active` → allow
- `past_due` → allow + `X-Subscription-Warning: past_due`
- `unpaid` / `cancelled` / unknown → `402` + `error.code=payment_required`

Frontend reaction:

- `lib/api/client.ts` detects `402`, sets `sessionStorage["legacy-payment-required"] = "1"`, dispatches event.
- `components/layout/app-layout.tsx` listens, blurs/locks shell and shows `PaymentRequiredModal`.

Error-handling matrix

Status	Code	Behavior
400	bad_request	validation/form hint
401	unauthorized	refresh once then `/login`
401	otp_required	keep on login, show OTP flow
402	payment_required	paywall + lock protected shell
403	forbidden	permission denied UX
403	pending_clinic	redirect `/account/*`
500/502/503	internal	generic safe message

5. Environment Setup

Prerequisites: Node.js `>=20`, npm

```
npm install
npm run dev
```

Config flags

Variable	Effect
`NEXT_PUBLIC_TRIAL_MODE`	Fallback trial behavior when `/health` unavailable
`NEXT_PUBLIC_PAYMENT_DEV_PREVIEW`	Render payment page without real auth in preview/dev
`NEXT_PUBLIC_MOCK_STRIPE_CHECKOUT`	Mock checkout fallback to `/payment/success?mock=1`
`NEXT_PUBLIC_ENABLE_DUMMY_LOGIN`	Enables demo login shortcut

6. Deployment Notes

Deployed to **Google Cloud Run** via `./deploy.sh`.

- Service: `legacy-dashboard`, region `europe-west2`, port `8080`.
- `--allow-unauthenticated` (public web app; API auth is enforced via Bearer token at the API).
- Memory `512Mi`, CPU `1`.
- Build is a standard `next build`. No server-side secret required for the web tier beyond what `app/api/auth/*` needs to reach Identity Toolkit.

7. Known Limitations / Risks

- **Hardcoded API base URL.** Switching environments requires editing `lib/portal-config.ts`.
- **Subscription enforcement is backend-driven.** The frontend can only blur/lock screens when the API returns `402`.
- **Non-admin subscription status.** Non-admins never fetch subscription status directly and rely solely on `402` signals.
- **Trial mode bypass.** If `/health` returns `trialMode: true`, auth and gating are relaxed by design.
- **Staff `/people` vs `/users`.** `/users` is read-only; `/people` is the management surface.
- **Refresh token in `sessionStorage`.** Sessions do not persist across browser restarts / new tabs by design.

8. QA / UAT Checklist

Pre-flight & Auth

- ☐ Confirm backend URL in `lib/portal-config.ts`.
- ☐ Check `<api>/health` and note `trialMode`.
- ☐ Valid login succeeds, invalid login shows safe error.
- ☐ OTP flow works (required, invalid, resend).
- ☐ Signout redirects to `/login`.

Subscription gating & Roles

- ☐ Unpaid user sees blur + paywall; cannot interact with protected screens.
- ☐ Active user and super_admin have normal access.

- [ ] past_due only shows soft banner.
- [ ] doctor/nurse/readonly do not see Users and Billing.
- [ ] Non-admin direct `/payment` access redirects away.

Device compare & Reports

- [ ] Compare loads via single `/api/devices/compare` flow.
- [ ] Create/update/delete automation schedule works.
- [ ] Validation errors shown for bad time/timezone/day fields.
- [ ] Manual send validates date range/recipients and handles success/errors.

Billing (admin/super_admin)

- [ ] Billing overview/payment method/invoices load.
- [ ] Checkout, cancel, resume, portal session, change-plan work.